生成AIセキュリティガバナンス導入の考え方

NISTを前提としたセキュリティガバナンスにAIセキュリティを組み込む二層構造（NIST AI RMF × OWASP GenAI）

IT部門内共有 ｜ 2026-10 ｜ v0.1

この資料で伝えたいこと

承認を求めるものではありません。考え方をIT部門内で正しく理解してもらうための資料です

目的

NIST前提のセキュリティガバナンス（CSF 2.0 導入済み）に、AIセキュリティのケイパビリティを組み込み、ガバナンスを安定させる

考え方：二層構造

NIST AI RMF／AI 600-1（ガバナンス層＝経営の言葉）と OWASP Top 10（技術対策層＝現場の言葉）を、公式の対応表でつなぐ

進め方：3段階

Phase 1 台帳と最優先3リスク → Phase 2 Tier別審査とレッドチーミング → Phase 3 対応表による統合管理

皆さんにお願いしたいこと

二層の役割分担、審査の仕組み（設計案）、各担当の役割を理解し、今後の論点の議論に参加してもらう

出典：proposal/ai-security-framework_proposal.md 第1節

生成AIは従来のIT管理では捉えきれないリスクを持ち込む

OWASP 2026年版の基本姿勢 *「騙されないモデルを作ろうとするのをやめ、モデルが騙されても重要なものが壊れないようにシステムを設計せよ」*

生成AIの性質	何が起きるか	関連リスク
指示とデータの区別がない	入力・検索結果・ツール出力が同じトークン列になり、確実な分離ができない	LLM01
出力が確率的	もっともらしい誤り（作話）が混ざる	LLM07
権限の委譲	エージェントがツールを選び、ユーザー権限で外部システムを操作する	LLM03 ASI02
データの残留	学習・埋め込み・メモリに入ったデータは、元データ削除後も抽出されうる	LLM02 LLM09
新しいサプライチェーン	事前学習モデル・アダプタ・MCPサーバなど検査が難しい部品に依存する	LLM04 ASI04

出典：OWASP Top 10 for LLM Applications 2026 / NIST AI 100-1 付録B（第1章）

既存の枠組みは、どちらか一方だけでは閉じない

AI RMFは「何を目指すか」、OWASPは「何を防ぐか」。役割が違うため、組み合わせて初めて閉じる

2 / 10

OWASP LLM Top 10 のうち、AI RMF とほぼそのまま対応するリスク

LLM04 サプライチェーン
LLM07 誤情報

残り8件は補助的な対応のみ
LLM10 は対応なし

AI RMF だけでは

「評価せよ（MEASURE 2）」「対応せよ（MANAGE）」とは言うが、何をどう評価・対応するかは言わない

→ プロンプトインジェクションや出力処理の技術対策が担保されない

OWASP だけでは

何を防ぎ、どう実装・検証するかは詳しいが、組織としての判断の仕組みを持たない

→ 誰が承認し、残留リスクを誰が受容するか（ GOVERN 2.3、MANAGE 1.4）が決まらない

出典：OWASP Top 10 for LLM Applications 2026, Appendix A（第6章）

目指す姿:ガバナンスが安定した状態

導入の到達点を5つの観点で定義する。ロードマップはこの状態に向けて段階を切る

1

把握

社内の生成AIがすべて台帳に載り、構成要素と責任者が分かる

GOVERN 1.6

MAP 4

2

判断

リスクに応じた水準で審査され、残留リスクの受容者が記録されている

GOVERN 1.3

GOVERN 2.3

MANAGE 1.4

3

実装

案件ごとにOWASPの対策が適用され、テストで確かめられている

MEASURE 2.7

4

監視・対応

稼働中のAIが監視され、異常時に停止でき、インシデントが通知される

MEASURE 2.4

MANAGE 2.4

MANAGE 4.3

5

説明

NISTとOWASPの両方の言葉で準拠状況を説明できる

GOVERN 4.2

出典:第1章 1.3(根拠は NIST AI 100-1 のサブカテゴリ)

二層構造：経営の言葉と現場の言葉を公式の対応表でつなぐ

ガバナンス層

NIST CSF 2.0（既存）
＋ AI RMF 1.0／AI 600-1（追加）

問い　どのAIを使ってよいか、誰が承認し、どう監督するか
担い手　経営層、CISO、セキュリティガバナンス、法務
成果物　方針、AI資産台帳、審査プロセス、残留リスクの記録

公式の対応表　Top 10 付録A（AI RMF・AI 600-1）／ GenAI Security Crosswalk（CSF 2.0）

技術対策層

OWASP LLM Top 10 2026（モデル＝部品）
OWASP Agentic Top 10 2026（モデル＝行為者）

問い　何が起きうるか、何で防ぎ、どう確かめたか
担い手　案件担当、アーキテクト、開発・運用
成果物　チェックシート、テスト結果、ガードレール設定

方針・必須指定が降りる↓　／　記録が集約されて上がる↑

出典：第1章 1.4／第6章

PART 1

依拠する枠組み

NIST（ガバナンス層）と OWASP（技術対策層）の中身と最新状況

NISTの文書は役割が分かれている

「何を目指すか」はCSF／AI RMF、「何をするか」はPlaybook、「生成AIで何を見るか」はAI 600-1

文書	役割	状況（2026-10）
CSF 2.0	組織全体のサイバーセキュリティ（ 6機能、GOVERN新設）	導入済み（前提）
AI RMF 1.0（AI 100-1）	AIリスクマネジメントの枠組み。4機能・19カテゴリ・72サブカテゴリ。公式日本語訳あり	改訂中
AI RMF Playbook	サブカテゴリごとの推奨行動と文書化の問い	公開済み
AI 600-1	生成AIプロファイル。12リスクと推奨行動（200件超）	公開済み
IR 8596 Cyber AI Profile	CSF 2.0 をAIに適用（Secure／Defend／Thwart）	準備草案
COSAiS	SP 800-53 のAI向けオーバーレイ（5ユースケース）	草案作成中

出典：NIST AI RMF ページ、CSRC（2026-10 確認）／第2章

AI RMFのコア：4機能と、本資料で使うサブカテゴリ

GOVERN は横断機能。MAP → MEASURE → MANAGE はライフサイクルに沿って繰り返す

GOVERN

6カテゴリ

- 1.3 リスク許容度に応じた活動レベル
- 1.6 AIシステムの棚卸し
- 1.7 安全な廃止
- 2.3 経営の意思決定責任
- 6.1・6.2 サードパーティ

MAP

5カテゴリ

- 2.2 知識の限界と人間によるオーバーサイト
- 3.5 ヒューマンオーバーサイトのプロセス
- 4.1・4.2 全構成要素のリスク

MEASURE

4カテゴリ

- 1.3 独立評価者の関与
- 2.4 実稼働時のモニタリング
- 2.7 セキュリティとレジリエンスの評価

MANAGE

4カテゴリ

- 1.3 対応の選択肢
- 1.4 残留リスクの文書化
- 2.4 停止・廃止の仕組み
- 3.2 事前学習済みモデルのモニター
- 4.3 インシデント通知

7特性のうち本資料の中心は「セキュリティとレジリエンス」。72サブカテゴリの実践内容はPlaybook（About／Suggested Actions／Transparency & Documentation）に示されている

出典：NIST AI 100-1 公式日本語訳 表1〜4（第2章 2.3）

AI 600-1：生成AI固有の12リスクと本資料の範囲

OWASPの10リスクと対応するのは7つ。残りは安全性・倫理の領域で、本資料の範囲外とする

01 **CBRN 情報・能力** 範囲外	02 **作話** LLM07・LLM03	03 **危険・暴力的・憎悪的コンテンツ** 一部（LLM05）	04 **データプライバシー** LLM02・LLM09
05 **環境影響** 範囲外	06 **有害なバイアス・均質化** 範囲外	07 **人間とAIの構成** LLM07・LLM03	08 **情報の完全性** LLM05・07・09
09 **情報セキュリティ** 10リスクすべての中心	10 **知的財産** LLM02・04・06	11 **わいせつ・侮辱的コンテンツ** 範囲外	12 **バリューチェーンと構成要素の統合** LLM04・LLM05

生成AIで重視する 4つの考慮事項：ガバナンス／コンテンツの来歴／導入前テスト／インシデント開示

推奨行動の例：GV-1.6-003 は、AI資産台帳に基盤モデルとバージョン、データの来歴、既知の問題、ヒューマンオーバーサイトの役割、知的財産・機密データの扱いを記載するよう求めている

出典：NIST AI 600-1（2024-07）、OWASP Top 10 2026 Appendix A（第2章 2.4）

OWASP 2026年版：実インシデントで順位を検証した初の版

エージェントでの実害を反映し「過剰な権限」が3位に。プロンプトインジェクションは防御効果を考慮して1位を維持

6,639件

分類した実インシデント（収集 7,714件）

公開脆弱性DB・AI被害DBから

75 : 25

実務者の投票 ： インシデントデータ

の重みで最終順位を決定

2026	リスク	2025	変化
LLM01	プロンプトインジェクション	01	**維持**
LLM02	機密情報の漏洩	02	**維持**
LLM03	過剰な権限	06	**↑3**
LLM04	サプライチェーン	03	**↓1**
LLM05	データ・モデルのポイズニング	04	**↓1**
LLM06	無制限のリソース消費	10	**↑4**
LLM07	誤情報	09	**↑2**
LLM08	隠されたコンテキストの露出	07	**改称・拡大**
LLM09	ベクトル・埋め込みの弱点	08	**↓1**
LLM10	不適切な出力処理	05	**↓5**

出典：OWASP Top 10 for LLM Applications 2026（v1.0, 2026-08-04）What's New（第3章）

LLM Top 10 2026（1/2）：全案件に適用する 10リスク

共通原則：信頼境界・権限・承認・検証を、モデルの外で決定論的に実装する

リスク		要点	決定的な対策
LLM01	プロンプトインジェクション	入力（直接・間接、画像・音声、メモリ）が振る舞いを変える。確実な防止策はない	資格情報と状態変更はアプリ側で再検証／重要操作は人が承認／Rule of Two
LLM02	機密情報の漏洩	回答だけでなくツール引数・ログ・埋め込みも漏洩経路。主因は上流の過剰共有	検索の前に認可／システムプロンプトに秘密を置かない
LLM03	過剰な権限	誤った・操作された出力が損害を伴う行動になる（過剰な機能・権限・自律性）	ツール・権限の最小化／ユーザーのコンテキストで実行／完全仲介
LLM04	サプライチェーン	モデル・データ・アダプタ・変換工程の改ざん、実在しないパッケージの悪用	提供者審査／AIBOM・ML-BOM／署名・ハッシュ固定
LLM05	データ・モデルのポイズニング	学習・埋め込み・RAGの汚染。復旧に再学習が必要になりコストが大きい	系譜管理／取り込み検証／トリガー探索

出典：OWASP Top 10 for LLM Applications 2026, LLM01〜LLM10（第4章）

LLM Top 10 2026（2/2）：全案件に適用する 10リスク

Rule of Two：(A)非信頼入力 (B)機密データ (C)状態変更・外部通信。3つそろえば操作ごとの人の承認が必須

リスク		要点	決定的な対策
LLM06	**無制限のリソース消費**	推論ループ、ツールのファンアウト、ウォレット枯渇、モデル抽出	**上書き不能な支出上限／サーキットブレーカー**
LLM07	**誤情報**	誤った出力が信頼され、判断や行動に使われること自体がリスク	**生成と実行の分離（Claim-Check-Act）／根拠性で評価**
LLM08	**隠されたコンテキストの露出**	システムプロンプトやツール定義の抽出・推測	**見つかる前提で設計し秘密を置かない／認可をLLMから独立**
LLM09	**ベクトル・埋め込みの弱点**	類似検索を突いた漏洩・汚染・妨害。埋め込みから原文を復元できる	**照会内でテナント範囲を適用／埋め込み漏洩＝原データ漏洩**
LLM10	**不適切な出力処理**	出力を検証せず下流へ渡しXSS・SQLi・RCE を招く	**出力の検証・エンコード／Markdown画像の自動描画を無効化**

出典：OWASP Top 10 for LLM Applications 2026, LLM01〜LLM10（第4章）

Agentic Top 10 2026：エージェント案件に上乗せする 10リスク

モデルが「行為者」になったら追加する。審査は「目標・権限・記憶・連携相手」の4点が軸

ASI01	目標の乗っ取り	Critical
ASI02	ツールの誤用・悪用	Critical
ASI03	ID・権限の悪用	Critical
ASI04	エージェントのサプライチェーン	High
ASI05	想定外のコード実行	Critical
ASI06	記憶・コンテキストの汚染	High
ASI07	安全でないエージェント間通信	High
ASI08	連鎖的な障害	High
ASI09	人とエージェントの信頼の悪用	Medium
ASI10	暴走エージェント	Critical

設計原則

最小エージェンシー　必要のない自律性を与えない

最小権限　ツール・資格情報・データを最小限に

全入力を非信頼として扱う　文書・ツール出力・他エージェントのメッセージ

人の承認・操作ごとの認可　高影響の操作は毎回検証する

可観測性と封じ込め　記録・逸脱検知・キルスイッチ・失効・ロールバック

隔離と検証　サンドボックス、署名・バージョン固定、レッドチーミング

出典：OWASP Top 10 for Agentic Applications 2026（2025-12-09）、重大度はGenAI Security Crosswalk（第5章）

PART 2

NISTとOWASPの統合と運用

公式の対応表、既存CSFとの接続、審査の仕組み、ロードマップ

公式の対応表から分かること

独自の対応表は作らない。版が固定されたOWASP Top 10 付録Aを一次根拠にする

OWASP × NIST AI 600-1

9 / 10

「情報セキュリティ」が主要な対応となるOWASPリスク

- 10リスクすべてが情報セキュリティにかかわる
- 誤情報（LLM07）は「情報の完全性・作話・人間とAIの構成」と強く結びつく
- → 業務部門の利用ルール（検証してから使う）とセットで管理する

OWASP × NIST AI RMF

2 / 10

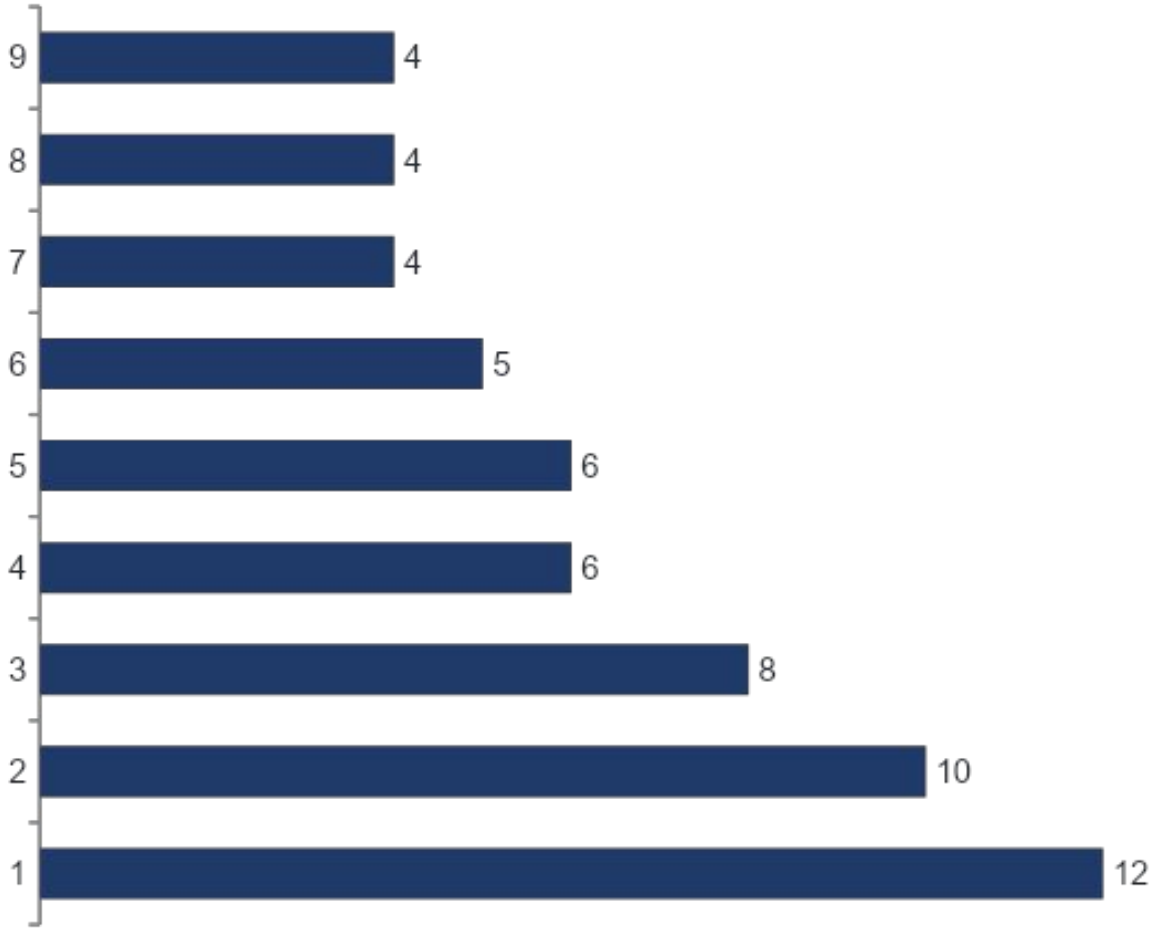
AI RMF のカテゴリとほぼそのまま対応する OWASPリスク

- LLM04 → GOVERN 6・MAP 4・MANAGE 3
- LLM07 → MEASURE 2
- 残りは補助的な対応、LLM10 は対応なし → 二層構造が必要な根拠

出典：OWASP Top 10 for LLM Applications 2026, Appendix A（第6章 6.3・6.4）

既存のCSF運用で、まず生成 AIを含めるべき箇所

OWASPの20リスク（LLM・Agentic）の主要な対応先は、既存のCSFサブカテゴリに集中している



既存運用への追加事項

- **DE.CM-01** プロンプト・ツール呼出・トークン消費を監視対象に加える
- **PR.DS** ベクトルDB・埋め込み・プロンプトログを機密データとして扱う
- **PR.AA** エージェントを非人間Dとして管理し、最小権限で動かす
- **GV.SC** モデル・データ・MCPサーバの提供者を供給者管理に加える
- **ID.AM-08** AI資産台帳を既存の資産台帳と統合する

出典：OWASP GenAI Security Crosswalk v4.0.0（LLM×CSF 2026-Q3、Agentic×CSF 2026-Q1）を集計（第6章 6.5）

同じ生成AIでも、RAG型とエージェント型では審査の焦点が違う

RAG型　社内FAQボットなど

焦点	データの境界：誰がどの文書を見られるか、何が漏れるか、誤答をどう検証させるか
Rule of Two	A・B は有り、C は無し（参照のみに限定）
最優先リスク	LLM02　LLM09　LLM07
決定的な対策	検索前の認可、データ側の過剰共有の解消、出典の表示
侵入時の被害	情報漏洩、誤った業務判断

エージェント型　チャットUI＋ハーネスなど

焦点	行動の境界：何をしてよいか、誰が承認するか、暴走をどう止めるか、出力をどう描画するか
Rule of Two	A・B・C すべて有り得る → 操作ごとの承認
最優先リスク	LLM03　LLM01　ASI02　ASI05　LLM06
決定的な対策	最小エージェンシー、完全仲介、人の承認、サーキットブレーカー
侵入時の被害	加えてデータ破壊・不正送信・不正実行

出典：第7章（COSAiS のユースケース区分に対応）

評価テンプレート：事前分類 5問でTierを決める

審査をリスクに比例させる。Tier 条件と受容者は設計案で、リスク許容度とあわせて今後確定する

事前分類5問

Q1 **データの機密性**
公開／社内限定／機密

Q2 **アーキテクチャ**
単体／RAG／エージェント／FT

Q3 **出力の自律性**
下書き／承認後実行／完全自動

Q4 **提供形態**
外部SaaS／社内構築／自社運用

Q5 **Rule of Two**
A・B・C の有無

High

Rule of Two で3つ／完全自動かつ外部への作用あり／機密エージェントまたはFT／社外の顧客等が直接利用

評価 専門部会＋独立評価者のレッドチーミング
受容者 **経営層（案）**

Medium

Rule of Two で2つ／機密データ／RAG またはエージェント

評価 セキュリティ担当の確認＋導入前テスト
受容者 **部門長（案）**

Low

上記以外

評価 セルフチェック（チェックシート記入）
受容者 **案件オーナー**

出典：第8章（根拠：GOVERN 1.3・2.3、MEASURE 1.3、MANAGE 1.4）

経営と現場の目線合わせ：同じ記録から両方の報告を出す

この往復が回っている状態を「ガバナンスが安定した状態」とする（集約の仕組みはPhase 3 で構築）

現場の記録
OWASP ID

- 事前分類の回答と Tier
- 技術設問の回答と証跡
- 未実施の理由・代替策・残留リスク・受容者

公式の対応表で変換
付録A／Crosswalk

- AI RMF の機能・カテゴリへ
- AI 600-1 のリスク区分へ
- CSF 2.0 のサブカテゴリへ

経営への報告
NIST の言葉

- Tier 別の案件数と審査状況
- AI RMF 機能別の充足状況
- AI 600-1 リスク別の露出
- OWASP ID 別の頻出未対策

逆方向　経営の方針（例：エージェントの不可逆操作は必ず人が承認）が、技術設問の「必須」指定として現場に降りる

出典：第8章 8.6

ロードマップ：NISTとOWASPを同時に進める 3段階

片方だけが先行しないよう、各 Phase でガバナンス層と技術対策層を対にして進める

Phase 1

ガバナンス拡張と基本対策の同時開始

NIST
- 生成AI利用方針
- AI資産台帳を既存台帳と統合
- 供給者管理にモデル・AIサービスを追加
- 暫定審査（事前分類5問）

OWASP
- 最優先 LLM01・LLM02・LLM10（エージェントは＋LLM03）
- 既存監視にプロンプト・ツール呼出・トークン消費を追加

完了の目安　全生成AIが台帳に載り、新規案件が審査を通る

Phase 2

ユースケース別評価の高度化

NIST
- Tier 別審査の本格運用
- 独立評価の体制
- 停止・廃止の手順と責任者

OWASP
- RAG：LLM09・LLM07
- エージェント：Agentic Top 10 全体
- High 案件のレッドチーミング

完了の目安　High 案件がすべてレッドチーミング済み

Phase 3

対応表による統合管理と監査運用

NIST
- 機能別・リスク別の経営報告
- インシデントの通知・追跡
- 年次のプロファイル見直し

OWASP
- 対応表で集約しダッシュボード化
- Crosswalk でギャップ確認
- OWASP 改訂の反映

完了の目安　経営報告と現場記録が同じデータから出ている

出典：第9章

外部の枠組みは動いている：追跡して正式版で差し替える

版を付録Aで固定し、改訂されたら見直す章を決めてある

対象	状況（2026-10）	正式版が出たときの対応
NIST AI RMF 改訂版	改訂中・未公開（AI行動計画に基づく）	番号・表現の変更を各章に反映。主に使うカテゴリは影響を受けにくい
NIST Cyber AI Profile（IR 8596）	準備草案公開済み（2025-12）、初期公開草案は2026年中の予定	CSF 対応の根拠を Crosswalk から置き換える
NIST COSAiS	予測AI版の注釈付きアウトライン（2026-01）まで	生成AI・エージェント版で対策をSP 800-53 管理策に対応付け
OWASP LLM／Agentic Top 10	2026年版	次版で順位・項目が変われば設問を更新
OWASP GenAI Security Crosswalk	v4.0.0、継続更新。多くの行が査読前	査読の進展にあわせて注記を見直す
AI事業者ガイドライン	第1.2版（2026-03）でAIエージェントを定義。本格的な扱いは次版	国内の説明責任の基準として更新

出典：NIST、OWASP、総務省・経済産業省（2026-10 確認）／第9章 9.5、付録A

IT部門の各担当に求めること

理解した後、それぞれの持ち場で何をするか



セキュリティガバナンス

AI資産台帳・評価テンプレートを整備し、既存 CSF 運用（DE.CM-01、PR.DS、PR.AA、GV.SC、ID.AM-08）に生成AIを組み込む



アーキテクト

RAG は「データの境界」、エージェントは「行動の境界」を設計の中心に置く



案件担当

案件ごとに事前分類とチェックシートを記入し、OWASP ID で記録する



運用

プロンプト・ツール呼出・トークン消費を監視し、停止手順を準備する

出典：proposal 10.2

まとめ：押さえてほしい 5点と今後決めること

押さえてほしい 5点

1. 目的はガバナンスの安定。別体系は作らず、既存CSFにAI RMF／AI 600-1を追加し、OWASPで具体化する
2. 二層は役割が違う。どちらか一方だけでは閉じない（AI RMFとほぼそのまま対応するのは10件中2件）
3. 対応表は独自に作らない。現場の記録（OWASP ID）がそのまま経営向けの集約（NIST）になる
4. プロンプトインジェクションは防げない前提。評価基準は「侵入されても被害が広がらないか」
5. 審査はリスクに比例させる。Tier 条件と受容者は設計案

今後IT部門内で決めること

- リスク許容度と Tier 条件の確定
- 残留リスクの受容者（Medium＝部門長、High＝経営層の案の是非）
- レッドチーミングを内製するか外部委託するか
- 経営層への提示の時期と内容（投資額を含む）

付録：参照した枠組みと版

版を固定して記録し、改訂時に見直す章を判断する基準にする

枠組み	版	主に使った箇所
NIST AI 100-1（AI RMF 1.0）＋ 公式日本語訳	1.0（2023-01）	コア・用語（全体）
NIST AI RMF Playbook	AIRC 版	評価テンプレートの設問
NIST AI 600-1（Generative AI Profile）	2024-07	12リスク、台帳の項目
OWASP Top 10 for LLM Applications	2026（v1.0, 2026-08-04）	10リスク、付録Aの対応表
OWASP Top 10 for Agentic Applications	2026（2025-12-09）	エージェントの10リスクと設計原則
OWASP GenAI Security Crosswalk	v4.0.0（2026-08-28）	CSF 2.0 との接続、重大度
NIST CSF 2.0／IR 8596／COSAiS	2024-02／準備草案／草案作成中	既存ガバナンス、追跡対象

出典：appendix/A_framework-sources.md